

D-SGSI-05: Declaración de Aplicabilidad (Statement of Applicability - SoA)

Universidad Nacional del Centro del Perú (UNCP)

SGSI ISO/IEC 27001:2022

Organización: Universidad Nacional del Centro del Perú (UNCP) **Versión:** 1.0 **Norma:** ISO/IEC 27001:2022 (Cláusula 6.1.3 d)

1. Introducción

Este documento define cuáles de los 93 controles de seguridad enumerados en el Anexo A de la norma ISO/IEC 27001:2022 aplican al Sistema de Gestión de Seguridad de la Información (SGSI) de la UNCP, cuáles se excluyen, la justificación de ambas decisiones, y su estado actual de implementación.

2. Metodología de Selección

La selección de los controles se ha basado en los resultados obtenidos tras aplicar la “Metodología de Evaluación y Tratamiento de Riesgos” (D-SGSI-04) a los activos críticos de la UNCP, así como en los requisitos legales (ej. Ley N° 29733) y los objetivos del PGTD 2026-2030.

3. Matriz de Declaración de Aplicabilidad (Muestra Representativa ISO 27001:2022)

(Nota: Esta es una plantilla con los controles más críticos según el PGTD de la UNCP. Durante la implementación real, la matriz en Excel (R-SGSI-01) deberá contener la evaluación de los 93 controles).

5. Controles Organizacionales (37 controles)

Control ISO 27001:2022	¿Aplica?	Justificación de Inclusión / Exclusión	Estado Actual de Implementación
5.1 Políticas para la seguridad de la información	Sí	Requerido por la norma y vital para establecer directrices.	Implementado. (D-SGSI-03: Política General SGSI aprobada).
5.2 Roles y responsabilidades de seguridad de la información	Sí	Necesario para asignar responsabilidades claras en la UNCP.	Implementado. (Oficial de Seguridad designado por Res. N° 2143-R-2023).
5.9 Inventario de información y otros activos asociados	Sí	Crítico para proteger el ERP ADESA, Campus Virtual y SIGA.	En Proceso. (Existe inventario 2025, requiere actualización SGSI).
5.10 Uso aceptable de la información y de los activos	Sí	Fundamental para regular el comportamiento de los 10,000 estudiantes y personal.	Planificado. (Requiere redacción de POL-01).
5.19 Seguridad de la información en las relaciones con proveedores	Sí	Vital debido a los servicios alojados en Huawei Cloud.	Planificado. (Requiere P-SGSI-07).

6. Controles de Personas (8 controles)

Control ISO 27001:2022	¿Aplica?	Justificación de Inclusión / Exclusión	Estado Actual de Implementación
6.1 Investigación de antecedentes	Sí	Necesario para personal de OTI y áreas que manejan datos sensibles (Centro Médico).	En Proceso. (A cargo de la Unidad de Recursos Humanos).
6.3 Concienciación, educación y formación en SI	Sí	Alineado al OGTD5 y OGTD6 del PGTD (Competencias digitales).	Planificado. (Proyecto PGTD-05).
6.7 Trabajo a distancia (Teletrabajo)	Sí	Aplica para personal administrativo con acceso VPN remoto.	Planificado. (Requiere POL-05).

7. Controles Físicos (14 controles)

Control ISO 27001:2022	¿Aplica?	Justificación de Inclusión / Exclusión	Estado Actual de Implementación
7.1 Perímetros de seguridad física	Sí	Necesario para proteger el Datacenter principal en Huancayo y sedes.	En Proceso. (Control de acceso existente, requiere mejora).
7.7 Equipo de escritorio y pantalla despejados	Sí	Prevenir fugas de información visual en oficinas y mesa de partes.	Planificado. (Requiere POL-02).

8. Controles Tecnológicos (34 controles)

Control ISO 27001:2022	¿Aplica?	Justificación de Inclusión / Exclusión	Estado Actual de Implementación
8.2 Gestión de derechos de acceso con privilegios	Sí	Crucial para proteger las bases de datos (ERP ADESA, SIGA).	En Proceso. (Requiere integración con PGTD-02 / IdM).
8.8 Gestión de vulnerabilidades técnicas	Sí	Necesario para el mantenimiento de los servidores (locales y cloud).	En Proceso. (Análisis periódicos por la OTI).
8.13 Copias de seguridad de la información	Sí	Crítico para la continuidad ante desastres o ransomware.	Implementado Parcialmente. (Cloud Backup 4TB, requiere POL-04).
8.16 Actividades de seguimiento (Monitoreo)	Sí	Requerido por la Ley de Ciberdefensa y para detectar intrusiones.	Planificado. (Implementación del TAP físico, NetFlow y SIEM según Anexo H.2 del PGTD).
8.24 Uso de criptografía	Sí	Requerido por la Ley N° 29733 para proteger datos personales.	En Proceso. (Certificados SSL y SNMPv3 según Anexo H.2 del PGTD).

4. Aprobación

El presente documento (SoA) ha sido revisado, refleja los riesgos actuales de la organización, y los controles listados son los adecuados para mitigar dichos riesgos.

__ **Oficial de Seguridad de la Información**

__ **Director(a) General de Administración (Líder GD)**